SSH Settings

Assuming people have an SSH server ready, you are going to pair up with a "lab partner" today and implement, and then test, each of the following SSH settings. The configuration file where these settings live is `/etc/ssh/sshd_config`.

> NOTE: Remember that any file(s) in `/etc/ssh/sshd_config.d` will override settings in the `sshd_config` file. They are applied in alphabetical order before `sshd_config`, and the first file to name a setting "wins."

Must cover

Setting	What it does	Why it's important
`PasswordAuthentication`	Allows or blocks logging in with a password. Ubuntu's default is `yes`.	Passwords can be guessed or stolen. Setting this to `no` forces key-based logins, which are much harder to break.
`PermitRootLogin`	Controls whether `root` can log in directly over SSH. Ubuntu's default is `prohibit-password` (keys only).	`root` is the first account attackers try. Setting this to `no` makes everyone log in as themselves and use `sudo`, which leaves a record of who did what.
`AllowGroups` / `AllowUsers`	Limits SSH logins to the groups or users you list.	Without it, any account with a password can log in. With it, only accounts you chose can get in.

Should cover

Setting	What it does	Why it's important
`KbdInteractiveAuthentication`	Allows or blocks "keyboard-interactive" logins, another way of typing a password. Ubuntu's default is `no`.	If this is `yes`, passwords can still work after you set `PasswordAuthentication no`. Turn both off.
`LogLevel`	Sets how much detail SSH writes to its logs. `VERBOSE` also records which key was used for each login.	Logs show who logged in, who failed, and when. Defenders find attacks by reading them.
`MaxAuthTries`	Limits how many login attempts one connection gets. Default is 6.	Slows down attackers trying password after password.

Setting	What it does	Why it's important
`LoginGraceTime`	Limits how long someone has to finish logging in. Default is 120 seconds.	Drops slow or stalled connections that tie up the server.
`PermitEmptyPasswords`	Allows or blocks logins to accounts with no password. Default is `no`.	An account with an empty password would let anyone in. Make sure this stays `no`.

Worth a mention

Setting	What it does	Why it's important
`X11Forwarding`	Lets graphical programs on the server display on your screen. Ubuntu's default is `yes`.	Every feature you don't need is one more thing an attacker can abuse. Turn it off if you don't use it.
`AllowTcpForwarding`	Lets SSH carry other network traffic through the connection (tunneling).	Attackers can use tunnels to reach other machines or sneak traffic past firewalls.
`AllowAgentForwarding`	Lets your SSH keys be used from the server to reach other machines.	If the server is compromised, an attacker could use your keys while you're connected.
`Banner`	Shows a message before login, such as an "authorized users only" warning.	Common real-world practice and sometimes a legal requirement. It doesn't stop attacks.
`Port`	Sets which network port SSH listens on. Default is 22.	Moving it cuts down on automated scans in the logs, but it's not real security. Attackers can still find the new port.
`ClientAliveInterval` / `ClientAliveCountMax`	Checks on idle connections and drops ones that stop responding.	Closes abandoned sessions so they can't be taken over later.